

Clase 179 — Reporte y métricas de Red Team

Parte: **7 — Red Team y operaciones ofensivas** · Fuente: *Red Team Development and Operations (Vest & Tubberville)* 🕒 Duración estimada: **90 min** · Nivel: **Intermedio**

🎯 Objetivo

Cerrar el ciclo de una operación con el entregable que le da valor: un informe claro, honesto y accionable, respaldado por métricas defensivas. El alumno aprenderá a estructurar un informe de Red Team, a narrar la ruta de ataque, a mapear cada acción a ATT&CK y a comunicar métricas como tiempo-a-detección y cobertura de forma que la dirección y el SOC actúen.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Estructurar** un informe de Red Team (executive + técnico).
- 2. **Narrar** la attack path de forma comprensible y reproducible.
- 3. **Mapear** hallazgos a ATT&CK y a recomendaciones concretas.
- 4. **Calcular** métricas de efectividad (TTD, TTR, cobertura, dwell time).
- 5. **Priorizar** recomendaciones por impacto y esfuerzo.

📖 Temas

#	Tema	Por qué importa
1	Audiencias del informe	Ejecutiva vs técnica
2	Resumen ejecutivo	Lo que lee la dirección
3	Narrativa de attack path	Cuenta la historia del compromiso
4	Evidencias y reproducibilidad	Credibilidad y remediación
5	Mapeo a ATT&CK	Lenguaje común y cobertura
6	Métricas (TTD/TTR/cobertura)	Miden a la defensa
7	Recomendaciones priorizadas	Convierten hallazgos en acción

📖 Definiciones y características

- **Resumen ejecutivo:** síntesis no técnica del riesgo y el impacto. Característica: sin jerga, orientada a decisiones.
- **Attack path narrative:** relato paso a paso de cómo se llegó al objetivo. Característica: reproducible y con evidencias.
- **TTD (Time To Detect):** tiempo desde una acción hasta su detección. Característica: mide la visibilidad del SOC.

- **TTR (Time To Respond)**: tiempo desde la detección hasta la respuesta. Característica: mide la reacción.
- **Dwell time**: tiempo que el atacante permanece sin ser detectado. Característica: métrica clave de exposición.
- **Cobertura ATT&CK**: qué técnicas fueron detectadas. Característica: se visualiza en Navigator y guía la mejora.

Herramientas y preparación

- El cuaderno de operación (Clase 176) con timestamps y evidencias.
- **ATT&CK Navigator** para la capa de cobertura del informe.
- Plantilla de informe (executive summary + narrativa + hallazgos + recomendaciones + apéndice técnico).
- Datos de detección del ciclo purple (Clase 178) para las métricas.

 El informe describe actividad autorizada y debe manejarse como información sensible: contiene el mapa para comprometer al cliente. Protege su distribución (cifrado, control de acceso) y respeta el NDA. Nada aquí implica ejecutar técnicas nuevas.

Laboratorio guiado (ejercicio aplicado)

1. **Reúne el material.** Toma el cuaderno de la operación en tu AD lab (foothold → AD → DA) con timestamps y capturas.
2. **Redacta el resumen ejecutivo.** Media página: objetivo, si se alcanzó, riesgo de negocio y 3 recomendaciones clave, sin jerga.
3. **Escribe la narrativa.** Cuenta el attack path en orden, cada paso con: acción, evidencia, ID ATT&CK y si fue detectado.
4. **Construye la tabla de hallazgos.** Cada hallazgo con severidad, impacto, técnica ATT&CK y recomendación priorizada.
5. **Calcula métricas.** Para cada fase, deriva TTD y TTR a partir de los timestamps del cuaderno y los datos del SOC; estima el dwell time global.
6. **Genera la capa de cobertura.** En Navigator, marca en verde/rojo las técnicas detectadas/no detectadas y expórtala como anexo.
7. **Prioriza recomendaciones.** Ordénalas en una matriz impacto/esfuerzo para que el cliente sepa por dónde empezar.

Ejercicios

1. Escribe un resumen ejecutivo de media página para una operación ficticia.
2. Redacta la narrativa de 3 pasos de un attack path con evidencias.
3. Crea una tabla de 5 hallazgos con severidad y recomendación.
4. Calcula TTD y TTR de dos fases a partir de timestamps dados.
5. Construye una capa de cobertura ATT&CK del ejercicio.
6. Prioriza 6 recomendaciones en una matriz impacto/esfuerzo.

Reto verificable

Produce un **informe de Red Team completo** de tu ejercicio en el AD lab: resumen ejecutivo, narrativa del attack path con mapeo ATT&CK, tabla de hallazgos, métricas (TTD/TTR/dwell/cobertura) y recomendaciones priorizadas. **Criterio de aceptación:** el informe permite a un ejecutivo entender el riesgo en la primera página y a un ingeniero reproducir y remediar cada hallazgo desde el detalle técnico; las métricas están respaldadas por timestamps reales del cuaderno y hay una capa de cobertura en Navigator adjunta.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Resumen lleno de jerga	La dirección no lo entiende; reescribe en lenguaje de negocio
Hallazgos no reproducibles	Faltan evidencias/pasos; usa el cuaderno con timestamps
Sin métricas	El ejercicio no se puede valorar; calcula TTD/TTR/dwell
Recomendaciones genéricas	No accionables; concreta acción, responsable y prioridad
Informe filtrable	Sensible sin protección; cífralo y controla el acceso

Preguntas frecuentes

? ¿Un informe de Red Team es como uno de pentest? Comparten estructura, pero el de Red Team enfatiza la **narrativa del attack path** y las métricas de detección/respuesta, no solo un catálogo de vulnerabilidades.

? ¿Debo listar TODO lo que hice? Lo relevante para reproducir y remediar, sí. El detalle exhaustivo va al apéndice técnico; el cuerpo cuenta la historia y prioriza.

? ¿Qué métrica valora más la dirección? El dwell time y el TTD/TTR: indican cuánto tiempo estuvo "dentro" el atacante y cómo respondió la organización, que es lo que el Red Team evalúa.

Referencias

- Vest & Tubberville — *Red Team Development and Operations* (reporting). <https://redteam.guide/>
- MITRE ATT&CK Navigator. <https://github.com/mitre-attack/attack-navigator>
- SANS — plantillas de reporting de Red Team.
- NIST SP 800-115 — reporting de pruebas de seguridad.

Siguiendo clase

Clase 180 - Adversary emulation con Atomic Red Team y Caldera